Semana 02 — Diagnosticar TLS y elegir parametros con medicion

Grupo 2 · rol Azul · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	02 de 10
Fase	1 — Fundamentos, criptografía y marco legal
Grupo	2
Rol	Azul
Entrega	GitHub, carpeta semana_02/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Parte de su propia captura cruda y aplica el control equivalente: configuración, parche o regla de red. Repite el ataque para demostrar que falla y documenta el antes y el después.

- Leer su propia evidencia cruda y elegir el control que corta el ataque en el punto más barato.
- Aplicar el control y repetir el ataque para demostrar que ya no funciona.
- Documentar el antes y el después con los mismos comandos y la diferencia medida.

2 Qué aporta este rol al entregable

La mitigación aplicada, el comando de verificación y la comparación de resultados.

3 Ejemplo paso a paso

El rol Azul parte de una configuracion que ya existe y comprueba si valida: lee el certificado, la cadena y el algoritmo, y elige los parametros de derivacion con una medicion propia.

3.1 Fijar la linea base del certificado y la cadena

Se inspecciona un sitio real y se guarda la salida completa. Emisor, fechas y algoritmo se leen del certificado, no de la pagina web.

```
mkdir -p semana_02/evidencia
openssl s_client -connect www.example.com:443 -servername www.example.com \
  -verify_return_error </dev/null > semana_02/evidencia/tls_handshake.txt 2>&1
openssl s_client -connect www.example.com:443 -servername www.example.com \
  -showcerts </dev/null 2>/dev/null \
  | openssl x509 -noout -issuer -subject -dates \
  | tee semana_02/evidencia/cert_resumen.txt
```

3.2 Leer algoritmo, clave publica y verificacion de la cadena

La cadena se valida contra el almacen del sistema. Si falla la validacion, esa linea del registro es el hallazgo: no se cambia el comando para que pase.

```
openssl s_client -connect www.example.com:443 -servername www.example.com \
  -showcerts </dev/null 2>/dev/null | openssl x509 -noout -text \
  | grep -E 'Signature Algorithm|Public-Key|DNS:' \
  | tee semana_02/evidencia/cert_detalle.txt
openssl s_client -connect www.example.com:443 -servername www.example.com \
  -CAfile /etc/ssl/certs/ca-certificates.crt -verify_return_error </dev/null \
  >/dev/null 2>semana_02/evidencia/cadena.txt; \
  grep -E 'Verify return code' semana_02/evidencia/cadena.txt
```

3.3 Comparar PBKDF2 y Argon2 con el mismo criterio

Se mide el coste de cada opcion con el mismo hardware y se elige la que sostiene el mismo tiempo objetivo con mas resistencia. Si Argon2 no esta instalado, se documenta la limitacion y se decide solo con PBKDF2.

```
python3 - <<'PY' | tee semana_02/evidencia/kdf_comparativa.txt
import hashlib, time
for iteraciones in (100_000, 600_000):
    t = time.perf_counter()
```

```
    hashlib.pbkdf2_hmac('sha256', b'clave', b'sal', iteraciones)
    print('pbkdf2', iteraciones, round(time.perf_counter() - t, 3), 's
        ')
try:
    from argon2.low_level import hash_secret_raw, Type
    t = time.perf_counter()
    hash_secret_raw(b'clave', b'sal', time_cost=3, memory_cost=65536,
                    parallelism=4, hash_len=32, type=Type.ID)
    print('argon2id', round(time.perf_counter() - t, 3), 's')
except ImportError:
    print('argon2 no disponible: se documenta como limitacion')
PY
```

3.4 Verificar que el repositorio no filtra secretos

Antes de entregar se busca material sensible con patrones y con el historial de git. Un secreto en un commit viejo sigue siendo un secreto expuesto.

```
git grep -nE 'BEGIN (RSA|OPENSSH|EC|PRIVATE) PRIVATE KEY' || true
git grep -nEi '(api[_-]?key|secret|token|password)[[:space:]]*=' ||
    true
git log --all --oneline -- semana_02/evidencia/*.pem || true
```

3.5 Configuracion observada y decision

Configuracion observada y decision

Elemento	Estado observado	Riesgo	Decision	Verificacion
Certificado	Emisor, fechas y DNS leidos	Caducidad o nombre incorrecto	Se documenta y se vigila la fecha	Salida en cert_resumen.txt
Cadena	Verify return code 0 contra el almacen del sistema	Cadena incompleta	Sin accion si valida	Salida en cadena.txt
Algoritmo de firma	Leido del certificado	Algoritmo debil o clave corta	Se reporta si es menor de 2048 bits	Linea en cert_detalle.txt
KDF	Tiempo medido por iteraciones	Coste insuficiente	600000 iteraciones como minimo	Tabla de tiempos
Secretos	Busqueda en arbol e historial	Clave privada versionada	Se retira y se rota	git grep sin resultados

La decision se justifica con la salida pegada; "correcto" sin evidencia no se acepta como verificacion.

4 Qué guardar en el repositorio

El informe incluye la lectura del certificado y su cadena, la comparacion de KDF con tiempos propios y la lista de verificaciones ejecutadas antes de entregar.

```
semana_02/
|-- informe.md
|-- evidencia/
|   |-- tls_handshake.txt
|   |-- cert_resumen.txt
|   |-- cert_detalle.txt
|   |-- cadena.txt
|   |-- kdf_comparativa.txt
|   `-- secretos.txt
`-- README.md
```

- La validacion de la cadena se ejecuta con el almacen del sistema, no con uno propio.
- La eleccion de iteraciones se apoya en tiempos medidos y repetidos.
- La busqueda de secretos cubre el historial, no solo el arbol actual.
- Si Argon2 no esta disponible, la limitacion esta escrita.

5 Cómo se corrige

Criterio	Peso
Cifrado y descifrado correctos con verificación de integridad	3,0
Firma y verificación demostradas, incluido el caso alterado	2,5
Lectura correcta del certificado y de la cadena	2,0
Medición de KDF con conclusión sobre coste y seguridad	1,5
Explicación de qué propiedad cubre cada primitiva	1,0
Total	**10,0**

- No se pega la clave privada ni el contenido del almacen de confianza en el informe.
- {'Un certificado valido no implica que el servicio sea seguro': 'se separan ambos juicios.'}

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.